

⚡ COMPLETE ROADMAP 2024

CyberSecurity Roadmap

From zero to professional – covering Foundations, SOC Analysis, and Penetration Testing. A complete visual guide for every stage of your journey.

5

LEARNING PHASES

2

CAREER PATHS

50+

TOOLS COVERED

20+

CERTIFICATIONS

● Mind Map

● Foundations

● Roadmap

● SOC Path

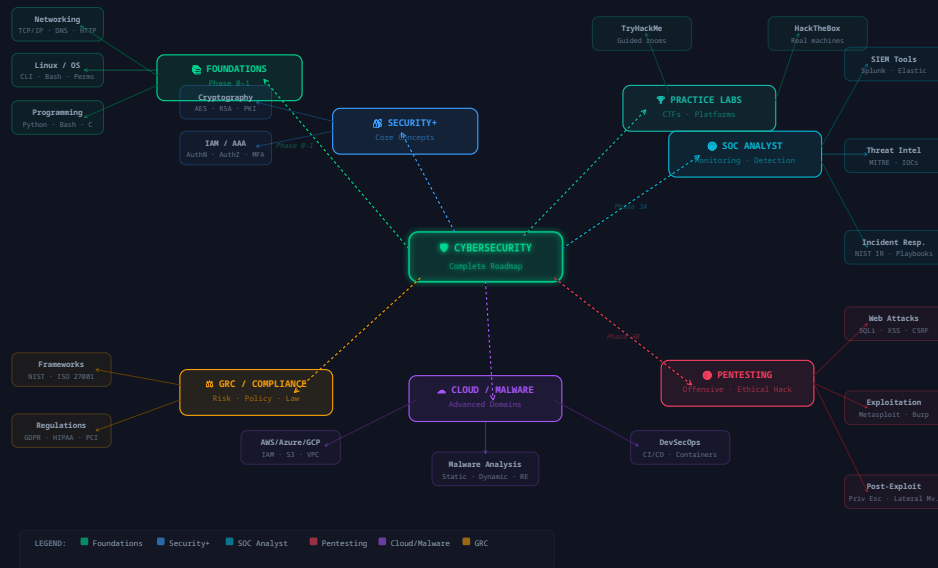
● Penetration



Cybersecurity Mind Map

Complete domain overview – all paths from a single view





Phase 0–2: Foundations

Build the technical base every cybersecurity professional needs

Before cybersecurity – master the fundamentals. Security is applied computer science. Without solid networking, OS, and programming knowledge, advanced security topics become guesswork. These phases form the irreplaceable bedrock.

PHASE 0 · 1–2 MONTHS

Networking Fundamentals

🕒 1–2 months

- ▶ OSI & TCP/IP models – layers, encapsulation, how data travels
- ▶ IP addressing, subnetting, CIDR notation
- ▶ Core protocols: DNS, DHCP, HTTP/S, FTP, SSH, SMTP, SNMP
- ▶ Routing & switching – VLANs, ARP, NAT, firewalls



- ▶ Wireshark – capture and analyze real traffic
- ▶ Packet Tracer / GNS3 for lab practice

[Professor Messer N+](#)

[CompTIA Network+](#)

[Cisco CCNA](#)

PHASE 0 · 2-3 MONTHS

Linux & Operating Systems

🕒 2-3 months

- ▶ Linux CLI mastery – navigate, manage files, permissions
- ▶ User/group management, sudo, chmod, chown
- ▶ Process management – ps, kill, systemd, cron
- ▶ Networking commands – netstat, ss, nmap, curl, wget
- ▶ Bash scripting – automate repetitive tasks
- ▶ Windows Active Directory basics, PowerShell intro

[OverTheWire: Bandit](#)

[Linux Journey](#)

[TryHackMe: Linux Fund.](#)

PHASE 1 · 2-3 MONTHS

Programming & Scripting

🕒 2-3 months

- ▶ Python – the security language; scripting, automation, parsing
- ▶ Write port scanners, password crackers, log parsers
- ▶ Bash scripting – glue Linux tools together
- ▶ Regular expressions – parse logs, extract indicators
- ▶ C/C++ basics – understand memory, buffers, pointers
- ▶ SQL basics – queries, injection concepts

[Automate the Boring Stuff](#)

[HackTheBox Academy](#)

[CS50P \(Harvard\)](#)

PHASE 1 · 2-3 MONTHS

Security Fundamentals



🕒 2-3 months

- ▶ CIA Triad, AAA, defense-in-depth
- ▶ Cryptography – symmetric, asymmetric, hashing, PKI, TLS
- ▶ Authentication – MFA, SSO, OAuth, certificates
- ▶ Common attack types – phishing, MITM, DoS, OWASP Top 10
- ▶ Firewalls, IDS/IPS, proxies, VPNs
- ▶ CompTIA Security+ certification prep

Professor Messer Sec+

CompTIA Security+

Cybrary

PHASE 2 · 1-2 MONTHS

Lab Setup & Practice

🕒 1-2 months

- ▶ Build a home lab – VirtualBox/VMware with Kali + vulnerable VMs
- ▶ Metasploitable, VulnHub, DVWA for safe practice
- ▶ TryHackMe beginner paths – Pre-Security, Intro to Cybersecurity
- ▶ Set up pfSense/OPNsense for network practice
- ▶ Practice Wireshark analysis on your own traffic
- ▶ Document everything – build your portfolio from day 1

TryHackMe

VulnHub

Kali Linux

PHASE 2 · ONGOING

Soft Skills & Career Prep

🕒 Ongoing

- ▶ Technical writing – clear, concise incident and pentest reports
- ▶ Create a GitHub portfolio with scripts and write-ups
- ▶ Join communities – Discord, Reddit r/netsec, DEF CON groups
- ▶ Attend BSides, DEF CON, local security meetups
- ▶ LinkedIn profile – highlight certifications and projects
- ▶ Build a blog or write CTF write-ups publicly



[GitHub](#)[LinkedIn](#)[DEF CON](#)

Full Learning Roadmap

End-to-end timeline from beginner to professional

● Phase 0: Pre-Security Foundation

Month 1-3

LEARN

- › Networking basics (OSI/TCP-IP)
- › Linux command line
- › Python fundamentals
- › Basic cryptography concepts

PRACTICE

- › OverTheWire: Bandit
- › TryHackMe: Pre-Security path
- › Packet Tracer labs
- › Python scripting tasks

GOAL

- › Understand how networks work
- › Navigate Linux confidently
- › Write basic Python scripts
- › Ready for Security+ study

● Phase 1: Security Fundamentals + Certification

Month 3-7

LEARN

- › CIA Triad, threat modeling
- › Cryptography deep dive
- › Identity & Access Management
- › Network security controls
- › Vulnerability management basics

CERTIFY

- › CompTIA Security+ (SY0-701)
- › CompTIA Network+ (optional)
- › Google Cybersecurity Certificate

GOAL

- › Pass CompTIA Security+



- › Build home lab with Kali
- › Understand attack categories
- › Ready to choose SOC or Pentest path

● Phase 2: Intermediate — Hands-On Hacking & Defense

Month 7-12

OFFENSIVE SKILLS

- › OWASP Top 10 in depth
- › Enumeration & reconnaissance
- › Metasploit framework basics
- › Burp Suite for web testing

DEFENSIVE SKILLS

- › Log analysis fundamentals
- › Splunk/ELK basics
- › MITRE ATT&CK framework
- › Basic incident response

PRACTICE

- › HackTheBox easy machines
- › TryHackMe Jr Penetration Tester
- › CTF competitions
- › Blue Team Labs Online

● Phase 3A: SOC Analyst Track

Month 12-18

TIER 1 SKILLS

- › Alert triage and prioritization
- › SIEM query writing (Splunk SPL)
- › Malware IOC analysis
- › Phishing email investigation

TIER 2 SKILLS

- › Deep packet inspection
- › Threat hunting techniques
- › SOAR automation
- › Digital forensics basics

CERTIFICATIONS

- › CompTIA CySA+
- › Splunk Core Certified
- › Blue Team Level 1 (BTL1)
- › EC-Council CEH (optional)



● Phase 3B: Penetration Testing Track

Month 12-18

CORE SKILLS

- › Recon – OSINT, Shodan, theHarvester
- › Scanning – Nmap, Masscan, Nikto
- › Exploitation – Metasploit, manual CVEs
- › Post-exploitation – Mimikatz, BloodHound

CERTIFICATIONS

- › eJPT (entry point)
- › CompTIA PenTest+
- › OSCP – the gold standard
- › CEH (optional)

SPECIALIZATIONS

- › Web app pentesting (OWASP)
- › Active Directory attacks
- › Social engineering
- › Mobile / API testing

● Phase 4: Advanced & Specialization

Month 18-36+

ADVANCED BLUE TEAM

- › Threat intelligence platforms
- › Malware reverse engineering
- › Cloud security (AWS/Azure)
- › CISSP / CISM (leadership)

RESEARCH & LEADERSHIP

- › 0-day research and CVE disclosure
- › Bug bounty programs
- › Conference talks & publishing
- › Security architecture design

ADVANCED RED TEAM

- › C2 frameworks (Cobalt Strike)
- › Custom exploit development
- › Red team operations planning
- › CRTE / CRYPTO certifications





SOC Analyst

Defend organizations by monitoring, detecting, and responding to threats in real-time. You are the immune system of IT infrastructure.

T1

Tier 1 – Alert Triage

Monitor SIEM dashboards, categorize alerts, first-level filtering of false positives. Tools: Splunk, QRadar, Microsoft Sentinel.

T2

Tier 2 – Incident Investigation

Deep-dive analysis on escalated alerts. Correlate events, analyze malware behavior, perform host forensics. Write investigation reports.

T3

Tier 3 – Threat Hunting

Proactively search for undetected threats. Use threat intelligence feeds, build detection rules, mentor junior analysts.

IR

Incident Response Lead

Coordinate response to major incidents. Lead forensic investigations, containment, eradication, and recovery operations.

★

Key Resources

Blue Team Labs Online · Splunk Training · SANS FOR508 · TryHackMe SOC Level 1 & 2 · BTL1 certification



Penetration Tester

Simulate real attackers to find vulnerabilities before malicious hackers do. You think like an adversary to protect the organization.

P1 Junior Pentester

Run vulnerability scans, test known CVEs, work on CTFs and HackTheBox. Assist senior testers. Learn methodologies: PTES, OWASP, OSSTMM.

P2 Mid-Level – Web & Network

Independently test web apps (OWASP Top 10), network infrastructure. Write professional pentest reports with CVSS-scored findings.

P3 Senior – Advanced Exploitation

Active Directory attacks, custom exploit development, bypass EDR/AV, complex environments. Lead assessments and mentor juniors.

RT Red Team Operator

Full adversary simulation campaigns. C2 infrastructure, physical intrusion, social engineering. APT-style multi-phase operations.

★ Key Resources

HackTheBox · PortSwigger Web Academy · TCM Security · TryHackMe · OSCP (OffSec PG Practice) · Bug Bounty platforms



Essential Tools

The toolkit every cybersecurity professional uses





Nmap

NETWORK SCANNING

Port scanning, service detection, OS fingerprinting. The cornerstone of network recon.

Free

Recon



Wireshark

PACKET ANALYSIS

Deep packet inspection, protocol dissection, traffic analysis for both offense and defense.

Free

Analysis



Metasploit

EXPLOITATION FRAMEWORK

Comprehensive exploitation framework with modules for thousands of CVEs. Pentest essential.

Free/Pro

Exploit



Burp Suite

WEB APP TESTING

Intercept proxy, scanner, intruder for web application security testing and OWASP analysis.

Free/Pro

Web



Splunk

SIEM PLATFORM

Industry-leading SIEM for log aggregation, correlation, alerting, and security dashboards.

Enterprise

SOC



BloodHound

AD ATTACK PATHS

Graph-based tool to visualize Active Directory attack paths and privilege escalation vectors.

Free

AD



Mimikatz

CREDENTIAL DUMPING

Windows credential extraction from memory. Essential for understanding Windows auth attacks.

Free

Post-Exploit



Hashcat

PASSWORD CRACKING

GPU-accelerated password cracking with support for 300+ hash types. World's fastest.

Free

Cracking



Shodan



OWASP ZAP



IOT / OSINT SEARCH

Search engine for internet-connected devices. Critical for external attack surface discovery.

Free/Pro

OSINT

WEB SCANNER

Free open-source web app security scanner. Good Burp alternative for automated scanning.

Free

Web



Kali Linux

PENTEST DISTRO

Debian-based distro with 600+ pre-installed security tools. The standard pentest OS.

Free

Platform



Autopsy

DIGITAL FORENSICS

GUI-based digital forensics platform for disk imaging, file carving, timeline analysis.

Free

Forensics



Certification Roadmap

Ordered from entry-level to elite – pick your track

Google CC

Google Cybersecurity Certificate

8-course Coursera path. Best starting point before Security+. No prerequisites.

ENTRY



CompTIA A+

CompTIA A+ (1101 & 1102)

IT fundamentals covering hardware, OS, troubleshooting. Optional but builds strong base.

ENTRY

CompTIA N+

CompTIA Network+

Networking fundamentals certification. Highly recommended before Security+.

ENTRY

Sec+

CompTIA Security+ SY0-701

The baseline certification. DoD-approved. Most job postings ask for this. Study: ~3 months.

MID

eJPT

eLearnSecurity Junior Penetration Tester

Practical hands-on exam. Best entry pentest cert. Fully practical, no MCQ.

MID

BTL1

Blue Team Level 1

Practical SOC analyst cert covering phishing, SIEM, threat intel, incident response.



MID

CySA+

CompTIA Cybersecurity Analyst+

Intermediate cert for SOC analysts. Covers behavioral analytics and threat intelligence.

MID

CEH

EC-Council Certified Ethical Hacker

Well-known pentest cert. More theoretical than OSCP but recognized in enterprise settings.

MID

PenTest+

CompTIA PenTest+

Intermediate pentest cert covering full pentest lifecycle. Good Sec+ progression.

ADVANCED

CASP+

CompTIA Advanced Security Practitioner

Senior-level technical security cert. Architecture, risk, research & collaboration.

ADVANCED

OSCP

Offensive Security Certified Professional



The gold standard pentest cert. 24-hour hands-on exam. "Try Harder" philosophy. Highly respected.

ELITE

CISSP

ISC² Certified Information Systems Security Professional
Management/architecture level. 5 years experience required. Opens doors to CISO roles.

ELITE

OSEP

Offensive Security Experienced Penetration Tester
Advanced evasion, C2 operations, bypassing defenses. For experienced red teamers.

ELITE

CRT0

Certified Red Team Operator
Cobalt Strike red team operations. Zero Points Security. Practical 48-hour exam.

ELITE



OWASP Top 10 — Web Vulnerabilities

The 10 most critical web application security risks – every pentester and SOC analyst must know these



A01 · CRITICAL

Broken Access Control

- Users can act outside intended permissions
- IDOR – access other users' data via ID manipulation
- Privilege escalation by modifying JWT or cookies
- Force browsing to authenticated pages
- **Test:** Burp Suite, manual parameter tampering

IDOR

Auth Bypass

A02 · CRITICAL

Cryptographic Failures

- Sensitive data transmitted in cleartext (HTTP, FTP)
- Weak or deprecated algorithms (MD5, SHA1, DES)
- Hardcoded secrets and keys in source code
- Improperly implemented TLS/SSL
- **Test:** Wireshark, SSL Labs, git-secrets

TLS

Secrets

A03 · CRITICAL

Injection

- SQL injection – manipulate database queries
- Command injection – execute OS commands
- LDAP, XPath, NoSQL injection variants
- User-controlled data sent to interpreter without validation
- **Test:** SQLmap, manual payload crafting

SQLi

RCE



A04 · HIGH

Insecure Design

- ▶ Missing or ineffective security controls by design
- ▶ No rate limiting on sensitive endpoints
- ▶ Business logic flaws (skip payment, bypass steps)
- ▶ Missing threat modeling in SDLC
- ▶ **Test:** Logic flow analysis, abuse cases

Logic Flaws

SDLC

A05 · HIGH

Security Misconfiguration

- ▶ Default credentials left unchanged
- ▶ Verbose error messages leaking internals
- ▶ Unnecessary features enabled (debug mode)
- ▶ Cloud storage buckets publicly accessible
- ▶ **Test:** Nikto, Nmap scripts, cloud config audit

Defaults

Cloud

A06 · HIGH

Vulnerable Components

- ▶ Outdated libraries with known CVEs
- ▶ Unpatched OS / web server versions
- ▶ Unmaintained third-party dependencies
- ▶ Log4Shell, Spring4Shell as real-world examples
- ▶ **Test:** OWASP Dependency-Check, Snyk, retire.js

CVEs

SCA

A07 · HIGH

Identification & Auth Failures



- Weak or default passwords allowed
- Credential stuffing not prevented
- Missing MFA on sensitive accounts
- Exposed session tokens in URLs
- **Test:** Hydra, credential stuffing tools

Brute Force

Sessions

A08 · HIGH

Software & Data Integrity Failures

- Insecure deserialization – arbitrary code execution
- CI/CD pipeline not secured (supply chain attacks)
- Auto-update without integrity verification
- SolarWinds / XZ Utils as real-world examples
- **Test:** Deserialization gadgets, supply chain audit

Deserialization

Supply Chain

A09 · MEDIUM

Security Logging & Monitoring Failures

- Logins and failures not logged
- Logs not monitored – breaches go undetected for months
- Alerts not triggered on suspicious activity
- Average breach detection time: 200+ days
- **Defend:** SIEM, alerting rules, log retention

SIEM

Detection

A10 · MEDIUM

Server-Side Request Forgery (SSRF)

- Server fetches attacker-controlled URLs
- Access internal metadata services (AWS 169.254.x)



- ▶ Pivot to internal network from web app
- ▶ Bypass firewall rules via trusted server
- ▶ **Test:** Burp Collaborator, internal IP payloads

SSRF

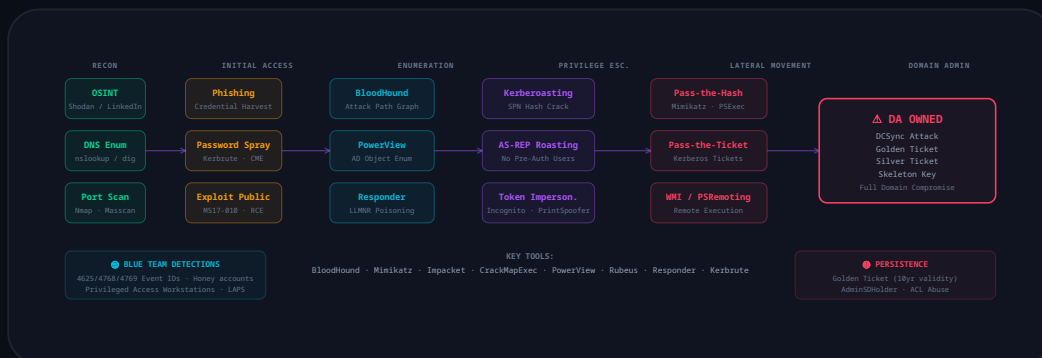
Cloud



Active Directory Attack Paths

The most targeted enterprise environment – essential for both red and blue teams

Why AD matters: Over 90% of Fortune 500 companies use Active Directory. Compromising AD = owning the entire organization. Most ransomware attacks pivot through AD to deploy across all machines.



KERBEROASTING

SPN Ticket Cracking

- ▶ Request TGS tickets for Service Principal Names
- ▶ Tickets encrypted with service account NTLM hash
- ▶ Crack offline with Hashcat (mode 13100)
- ▶ Tool: Rubeus.exe kerberoast



- Defense: Use Group Managed Service Accounts (gMSA)

🕒 DCSYNC ATTACK

Domain Controller Replication

- Mimic DC replication to pull all NTLM hashes
- Requires: Replicating Directory Changes permissions
- Dump krbtgt hash → Golden Ticket attack
- Tool: `mimikatz lsadump::dcsync`
- Defense: Monitor DS-Replication event IDs

🕒 GOLDEN TICKET

Forged Kerberos Tickets

- Forge TGTs using stolen krbtgt hash
- Valid for any user, any group, any time
- Persists even after password resets
- Tool: `mimikatz kerberos::golden`
- Defense: Reset krbtgt password TWICE

🕒 PASS-THE-HASH

NTLM Hash Reuse

- Use NTLM hash without cracking the password
- Authenticate to remote systems laterally
- Works against SMB, WMI, RDP (with creds)
- Tool: `CrackMapExec smb -H [hash]`
- Defense: Enable Protected Users group, LAPS



Understanding how malware works – essential for SOC and threat intel roles

4 STATIC ANALYSIS

Analyze Without Running

- ▶ Hash identification – MD5/SHA256, check VirusTotal
- ▶ String `strings` for extraction `malware.exe` IoCs –
- ▶ PE header analysis – imports, sections, entropy
- ▶ Disassembly – IDA Pro, Ghidra (free), Binary Ninja
- ▶ YARA rule writing to detect malware families
- ▶ Identify packers with PEiD / Detect-It-Easy
- ▶ Check imports for suspicious API calls (VirtualAlloc, WriteProcessMemory)

Ghidra

YARA

VirusTotal

5 DYNAMIC ANALYSIS

Observe Live Behavior

- ▶ Snapshot VM before execution – restore after
- ▶ Process Monitor – file/registry/network activity
- ▶ Wireshark – capture C2 traffic and DNS queries
- ▶ API Monitor – trace Windows API calls in real time
- ▶ x64dbg / OllyDbg for dynamic debugging
- ▶ FakeNet-NG – simulate internet to capture beacons
- ▶ Cuckoo Sandbox / Any.run for automated detonation

Cuckoo

x64dbg

Any.run



RAT (Remote Access Trojan)

MALWARE TYPE

Gives attacker full remote control. Keylogging, screenshot capture, file exfil, webcam



Ransomware

MALWARE TYPE

Encrypts files, demands payment. Modern strains exfiltrate data first (double extortion). Examples: LockBit, Revil, BlackCat.



access. Examples: njRAT, AsyncRAT, Quasar.



Rootkit

MALWARE TYPE

Hides malware presence at kernel or hypervisor level. Extremely persistent. Requires offline forensics or UEFI scanning to detect.



Botnet

MALWARE TYPE

Network of infected machines (bots) controlled via C2. Used for DDoS, spam campaigns, credential stuffing. Examples: Mirai, Emotet.



Spyware / Infostealer

MALWARE TYPE

Silently harvests credentials, browser cookies, clipboard data. Examples: Redline, Vidar, Raccoon Stealer. Common in phishing.



Fileless Malware

MALWARE TYPE

Runs entirely in memory – no file written to disk. Uses PowerShell, WMI, or LOLBins. Very hard to detect with file-based AV.



Cloud Security

AWS · Azure · GCP – the new attack surface every security professional must understand

▲ AWS SECURITY

Amazon Web Services

- ▶ **IAM** – overprivileged roles, assume-role attacks, confused deputy
- ▶ **S3** – misconfigured public buckets, ACL bypass, bucket enumeration
- ▶ **EC2** – SSRF to metadata API (169.254.169.254), IMDSv1 attacks
- ▶ **Lambda** – environment variable secrets, event injection
- ▶ **CloudTrail** – logging disabled detection, API abuse



- ▶ Tools: Pacu (AWS exploit framework), ScoutSuite, Prowler

[Pacu](#)[ScoutSuite](#)[CloudTrail](#)

▲ AZURE SECURITY

Microsoft Azure

- ▶ **Entra ID** (AAD) – conditional access bypass, device registration abuse
- ▶ **Service Principals** – overprivileged app registrations
- ▶ **Managed Identity** – SSRF to IMDS endpoint
- ▶ **Storage Accounts** – SAS token leaks, blob public access
- ▶ **Defender for Cloud** – security posture management
- ▶ Tools: ROADtools, MicroBurst, AzureHound (BloodHound)

[AzureHound](#)[ROADtools](#)

🔒 CLOUD SECURITY FUNDAMENTALS

Universal Concepts

- ▶ **Shared Responsibility Model** – what cloud secures vs you
- ▶ **Zero Trust** – never trust, always verify, least privilege
- ▶ **CSPM** – Cloud Security Posture Management tools
- ▶ **CWPP** – Cloud Workload Protection Platforms
- ▶ **Container Security** – Docker escapes, K8s RBAC attacks
- ▶ Certifications: AWS Security Specialty, AZ-500, CCSP

[AZ-500](#)[AWS-SSS](#)[CCSP](#)



Incident Response Process

NIST SP 800-61 framework – the structured approach to handling security incidents



INCIDENT SEVERITY LEVELS

- ▶ **P1 Critical** – Active ransomware, data breach in progress, DA compromised
- ▶ **P2 High** – Confirmed malware, unauthorized privileged access
- ▶ **P3 Medium** – Phishing email clicked, suspicious lateral movement
- ▶ **P4 Low** – Policy violation, port scan from external

DIGITAL FORENSICS — KEY ARTIFACTS

- ▶ **Windows:** Event logs, prefetch, registry, \$MFT, Amcache, LNK files
- ▶ **Linux:** /var/log/auth.log, bash_history, /proc/, crontab, syslog
- ▶ **Network:** PCAP files, NetFlow/IPFIX, firewall logs, DNS logs
- ▶ **Memory:** Volatility for RAM forensics, process trees, network conns

KEY IR TOOLS

- ▶ **Volatility3** – Memory forensics framework
- ▶ **Autopsy / FTK** – Disk forensics GUI
- ▶ **KAPE** – Rapid triage artifact collection
- ▶ **Velociraptor** – Live endpoint forensics at scale



- ▶ **TheHive** – Open source IR case management

GRC — Governance, Risk & Compliance



The business side of security – frameworks, regulations, and risk management

NIST CSF 2.0

Cybersecurity Framework

- ▶ **GOVERN** – Policies, roles, risk strategy (new in 2.0)
- ▶ **IDENTIFY** – Asset inventory, risk assessment
- ▶ **PROTECT** – Access controls, training, data security
- ▶ **DETECT** – Anomalies, continuous monitoring
- ▶ **RESPOND** – Incident response plans
- ▶ **RECOVER** – Restore services, communications

ISO 27001

Information Security Management

- ▶ International standard for ISMS
- ▶ 114 controls across 14 domains
- ▶ Risk assessment and treatment methodology
- ▶ Certification audited by accredited body
- ▶ Required by many enterprise contracts
- ▶ Pairs with ISO 27002 (implementation guidance)

PCI DSS V4.0



Payment Card Industry

- ▶ Mandatory for any org processing card payments
- ▶ 12 requirements covering network, access, encryption
- ▶ Quarterly external vulnerability scans
- ▶ Annual penetration test required
- ▶ SAQ (Self-Assessment) or QSA audit
- ▶ Non-compliance = fines + loss of card processing

HIPAA

Health Data Security (US)

- ▶ Protects PHI – Protected Health Information
- ▶ Administrative, physical, technical safeguards
- ▶ Breach notification within 60 days
- ▶ Business Associate Agreements required
- ▶ OCR investigates violations – fines up to \$1.9M
- ▶ Encryption of PHI at rest and in transit

GDPR

EU Data Protection Regulation

- ▶ Applies to any org handling EU citizens' data
- ▶ 72-hour breach notification to supervisory authority
- ▶ Right to erasure, data portability, access
- ▶ Privacy by design and by default
- ▶ Fines up to 4% of global annual turnover
- ▶ Data Protection Officer (DPO) role required

RISK MANAGEMENT

Core Concepts

- ▶ **Risk = Threat × Vulnerability × Impact**
- ▶ Risk appetite – how much risk is acceptable



- Qualitative vs quantitative risk assessment
- Treat / Tolerate / Transfer / Terminate (4T)
- CVSS scoring – base, temporal, environmental
- Risk register – document, track, and review



12-Month Study Plan

A realistic schedule for going from beginner to job-ready

Realistic time commitment: 10-15 hours/week consistently will get you job-ready in 12 months. Quality over quantity – deep understanding beats surface-level breadth. Always be building your portfolio alongside studying.

Months 1–2

Networking + Linux

- Work through Professor Messer Network+ videos
- Complete OverTheWire Bandit (all 34 levels)
- Set up VirtualBox + Kali Linux VM
- Daily: 30 mins networking labs in Packet Tracer
- Weekly: 1 TryHackMe beginner room

OTW Bandit

TryHackMe

Months 3–4

Python + Security+

- Python: Automate the Boring Stuff (free online)
- Write: port scanner, password gen, log parser
- Begin Professor Messer Security+ course
- Daily: 1 TryHackMe room + flashcards
- Weekly: 1 Python project from scratch



Python

Sec+ Prep

Months 5–6

Certify + Practice

- Take CompTIA Security+ exam – target 80%+ on practice tests first
- Start TryHackMe Jr Penetration Tester path
- Set up Metasploitable2 home lab
- Complete DVWA (all vulnerabilities)
- First CTF competition (PicoCTF)

CompTIA Sec+

CTF

Months 7–8

Choose Your Path

- **SOC:** TryHackMe SOC Level 1 path, Splunk fundamentals
- **Pentest:** TCM Security Practical Ethical Hacking, eJPT prep
- Start HackTheBox – 2 easy machines/week
- Build GitHub with write-ups and scripts
- Attend local BSides / security meetup

TCM Security

HackTheBox

Months 9–10

Intermediate Cert

- **SOC:** Study and take BTL1 or CySA+ exam
- **Pentest:** Take eJPT exam, begin OSCP prep
- HTB: Medium machines, focus weak areas
- Build a full portfolio project (own vuln report or detection rule set)
- LinkedIn profile complete, start applying to entry roles

BTL1 / eJPT

Job Hunt

Months 11–12

Job Ready



- Active job applications – Tier 1 SOC or Junior Pentester
- Mock technical interviews – practice explaining your labs
- **SOC:** Continue CySA+, Splunk cert
- **Pentest:** OSCP labs (90-day subscription)
- Final portfolio review – clean, documented, public

Interviews

Portfolio



Quick Reference: Platforms & Resources

Best learning platforms for each stage

🔗 PRACTICE PLATFORMS

- **TryHackMe** – Beginner-friendly, guided paths
- **HackTheBox** – Realistic machines, CTF-style
- **PortSwigger Academy** – Best free web security labs
- **PicoCTF** – Beginner CTF by CMU
- **CTFtime.org** – Global CTF calendar
- **VulnHub** – Downloadable vulnerable VMs

📖 LEARNING RESOURCES

- **TCM Security** – Affordable, practical courses
- **INE / eLearnSecurity** – Structured learning paths
- **SANS Institute** – Premium industry training
- **Cybrary** – Free SOC & security courses
- **IppSec (YouTube)** – HTB walkthroughs, learning goldmine



- ▶ **John Hammond (YouTube)** – CTF walkthroughs

OSINT & RECON

- ▶ **Maltego** – Visual link analysis, OSINT
- ▶ **theHarvester** – Email, subdomain enumeration
- ▶ **Shodan** – Internet-facing asset discovery
- ▶ **OSINT Framework** – Tool directory for OSINT
- ▶ **Recon-ng** – Web recon framework
- ▶ **SpiderFoot** – Automated OSINT

DEFENSIVE RESOURCES

- ▶ **MITRE ATT&CK** – Adversary TTP knowledge base
- ▶ **AlienVault OTX** – Threat intelligence sharing
- ▶ **VirusTotal** – File / URL malware analysis
- ▶ **Any.run** – Interactive malware sandbox
- ▶ **Elastic Stack** – Free SIEM alternative to Splunk
- ▶ **OpenCTI** – Open source threat intel platform

Cybersecurity Roadmap

Compiled for the security community · From zero to professional

Beginner → Foundations → Security+ → **Choose:** SOC Analyst or Pentesting →
Advanced: Specialization & Certs

The security landscape evolves rapidly – always verify tools, CVEs, and certifications against current sources.



⚠ All techniques and tools listed are for authorized, legal, and ethical use only.

